

Deployment of Network Security Controls

Justin Singh-Atwal, n11605618

1. Portfolio 1 – Vulnerability Management

1.1. Introduction to Vulnerability Scanning and Prioritisation

Purpose of vulnerability scanning: Vulnerability scanning helps identify weaknesses in software and system configurations so organisations can see where they might be at risk. It creates a list of potential issues, such as missing patches, outdated software, or misconfigured services, that can then be addressed.

Why prioritisation matters: Not every vulnerability carries the same risk. Prioritisation ensures that the most critical issues, like those that could allow remote attacks, are fixed first. This prevents organisations from spending time on low-risk issues while serious threats remain.

How it fits into network security: Scanning and prioritisation are part of ongoing vulnerability management. They support patching cycles, firewall or isolation measures, and incident response, helping organisations continuously reduce risk.

1.2. Role of NVD in Vulnerability Scanning and Prioritisation

The National Vulnerability Database (NVD) is a public repository that collects information on known software and system vulnerabilities, including CVE identifiers, CVSS scores, CWE classifications, affected products, and links to advisories or exploits. It provides standardised details that allow security teams to consistently compare, prioritise, and track vulnerabilities, while also serving as reliable evidence for audits and reporting. In practice, after a vulnerability scan identifies services or software versions, analysts consult the NVD to review severity, potential impact, and exploitability, which helps them decide which issues should be addressed first.

1.3. Identification, Assessment and Prioritisation of Vulnerable Services

To find vulnerabilities on the target host, I ran a network scan from Kali using the command (`sudo nmap -sV -O 172.0.1.2`). This scan showed all the open ports, the services running on them, and their version numbers. The results, shown in Figure 1, give a clear picture of which services might be at risk. The screenshot includes both the command and the list of detected services for transparency.

After identifying the services, I assessed each one to see how risky it was. I looked at three main things: the CVSS score, exploitability, and potential impact. The CVSS score shows how severe a vulnerability is, with higher numbers being worse. Exploitability is about how easy it is for an attacker to take advantage of the vulnerability, such as whether it can be reached over the network and if it needs a password. Impact is about what could happen if the vulnerability is exploited, like losing data, having

systems taken over, or causing a service to go down. Using these factors helps decide which vulnerabilities need attention first.

From this assessment, I picked the top five vulnerabilities to focus on. The vsftpd backdoor and Samba smbd were the most critical because they are network-facing, don't require authentication, and allow attackers to run code remotely. UnreallRCd and telnetd come next because they could cause a denial of service or allow remote code execution, and there are known ways to exploit them. VNC is also risky due to weak session security, but its impact is smaller compared to the others, so it was given lower priority.

For each of these top five vulnerabilities, I documented the service, CVE and CWE IDs, a short description, the CVSS score, attack vectors, affected product, and what should be done to fix it. This makes it clear which services are most dangerous and what actions need to be taken first, helping to reduce the overall risk to the network.

1.4. Complementary Controls for Vulnerability Scanning and Prioritisation

Combining scanning with threat intelligence: Using feeds like vendor advisories, Exploit-DB, or CISA's Known Exploited Vulnerabilities (KEV) helps identify which vulnerabilities are actively being exploited. This allows teams to focus on the highest-risk issues first.

Why it helps: Scans can produce a long list of vulnerabilities, but threat intelligence highlights the ones that are a real, immediate threat. For example, if a scanned host matches a CVE listed in the CISA KEV catalogue or has public exploit code available, it should be treated as a high-priority issue.

1.5. Top 5 definitions

Here are some definitions for the criteria:

CVSS score (severity): a standardised numeric value (and qualitative label) that summarises the technical severity of a vulnerability.

Exploitability: how easy it is for an attacker to exploit the issue (network access vs local, required authentication, complexity).

Impact: the likely business/technical consequence if exploited (e.g., data loss, full remote compromise, DoS).

Table 1 Top 5 Vulnerable services details showing some of the characteristics of the vulnerabilities

Vulnerable service	CVE	CWE	Short description	Severity	Associated Vectors	Affected Product	Remediation action
vsftpd 2.3.4 (FTP)	CVE-2011-2523	CWE-78	A backdoored build of vsftpd 2.3.4 opens a hidden shell on the host (port 6200), allowing an attacker to run commands remotely.	9.8 Critical	CVSS:3.1 / AV:N / AC:L / PR:N / UI:N / S:U / C:H / I:H / A:H (network, no auth, high impact)	vsftpd 2.3.4	Immediately stop/disable the FTP service and isolate the host; remove the compromised binary and install a clean, patched vsftpd; block FTP at the perimeter if not required.
Samba smbd (ports 139/445)	CVE-2017-7494	CWE-94	Allows an unauthenticated client to upload a library to a writable share and get the server to load it, causing remote code execution.	9.8 Critical	CVSS:3.1 / AV:N / AC:L / PR:N / UI:N / S:U / C:H / I:H / A:H (network, unauthenticated RCE)	Samba versions 3.5.0 affected ranges up to 4.6.4 / 4.5.10 / 4.4.14	Patch or upgrade Samba to a fixed release; remove or secure writable anonymous shares; restrict SMB access to trusted networks and monitor SMB writes.
UnrealIRCd (IRC, port 6667)	CVE-2023-50784	CWE-120	Websocket input handling can overflow a buffer, crashing the server and possibly allowing code execution on some platforms.	7.5 High	CVSS:3.1 / AV:N / AC:L / PR:N / UI:N / S:U / C:N / I:N / A:H (network, unauthenticated, DoS/possible RCE)	UnrealIRCd 6.1.0–6.1.3	Update to the patched UnrealIRCd (≥6.1.4); disable WebSocket features if unused; restrict exposure of the IRC service to internal networks
telnetd (port 23)	CVE-2022-39028	CWE-476	Certain telnetd implementations can hit a NULL pointer and crash; repeated crashes may take the telnet service offline (DoS).	7.5 High	CVSS:3.1 / AV:N / AC:L / PR:N / UI:N / S:U / C:N / I:N / A:H (network, unauthenticated, DoS)	telnetd (GNU inetutils / netkit variants)	Remove or disable telnetd and replace with SSH; if telnet must remain, apply vendor fixes, restrict access with ACLs, and enable monitoring for crashes.
VNC (port 5900, protocol 3.3)	CVE-2002-1511	CWE-255	Older VNC wrapper used weak random cookies, making session cookies predictable and increasing the risk of session hijacking.	5.0 Medium	CVSS 2.0: AV:N / AC:L / Au:N / C:P / I:N / A:N (network, unauthenticated, info disclosure/partial)	Old VNC / TightVNC versions (3.x / 1.x)	Replace with a modern VNC or remove the service; require strong authentication and tunnel VNC over SSH or VPN; block VNC from external networks.

I chose these five because they score highest on the factors that actually matter when deciding what to fix first: published severity (CVSS), how reachable and easy the flaw is to exploit (network-facing services that don't require authentication are much more dangerous), and the realistic business impact if an attacker succeeds (data theft, full remote control, or service outage). I also weighed whether public proof-of-concepts or exploit code exist, how broad the affected version range is, and how disruptive the fix will be a remotely exploitable RCE with a public exploit and a large, affected population is top priority even if patching takes some coordination. That reasoning puts the vsftpd backdoor and the Samba RCE at the top: both are network-exposed, require no credentials, have high CVSS scores, and have known public exploitation paths, so they give attackers the fastest route to full compromise. UnrealIRCd and the telnet daemon are next because both can be crashed or abused remotely (and in some cases may allow code execution), making them high risk for availability and potential escalation. VNC is lower priority here: predictable cookies weaken session security but compared with the other entries its exploitability and likely impact on core services are smaller, so address it after containment and the critical RCEs are handled

Command used: sudo nmap -sV -O 172.0.1.2

Scan date/time: 2025-10-03

```
(kali@kali)-[~]
$ sudo nmap -sV -O 172.0.1.2
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-03 08:21 EDT
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 56.52% done; ETC: 08:22 (0:00:05 remaining)
Stats: 0:00:24 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 78.26% done; ETC: 08:22 (0:00:03 remaining)
Stats: 0:00:30 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 86.96% done; ETC: 08:22 (0:00:02 remaining)
Stats: 0:01:18 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 08:22 (0:00:03 remaining)
Stats: 0:01:38 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 95.65% done; ETC: 08:23 (0:00:04 remaining)
Stats: 0:02:51 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 100.00% done; ETC: 08:24 (0:00:00 remaining)
Stats: 0:03:06 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.00% done; ETC: 08:24 (0:00:00 remaining)
Nmap scan report for 172-0-1-2.lightspeed.brhmal.sbcglobal.net (172.0.1.2)
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:4E:EF:9D (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 189.30 seconds
```

Figure 1 – Nmap scan showing vulnerable services on the target host

I matched each service and version from the Nmap output to NVD entries by searching the NVD for CVE records that list the same product and version range (CPEs). Where multiple CVEs apply, I prioritised those with the highest CVSS, public exploitability evidence, and direct network exposure.

2. Portfolio 2 – Intrusion Detection System

2.1. Introduction to Intrusion Detection System – Snort

An Intrusion Detection System (IDS) monitors network traffic to identify suspicious activities, policy violations, or known attack patterns. Its main purpose is to detect and alert administrators about potential security threats before they escalate. Snort is a widely used IDS that inspects network traffic in real time, using rule-based signatures to detect attacks. It supports features such as packet logging, real-time alerting, and flexible deployment modes, making it an effective example of a network security tool.

2.2. Different ways to use or deploy Snort

Snort can be deployed in multiple ways depending on the security needs:

- **Snort as a network-based IDS:**

- *Description: Snort monitors traffic passing through a network segment and inspects packets for malicious patterns. It operates in passive mode, only alerting or logging suspicious activity without interfering with the traffic. This is the simplest and most foolproof method for demonstrating detection.*
- *Command: `sudo snort -A console -q -c /etc/snort/snort.conf -i enp0s3 --daq pcap`*
- *Explanation: Using the pcap DAQ ensures Snort only reads packets, avoiding inline issues and host connectivity problems. It is ideal for testing and demonstration in virtualized lab environments.*

- **Snort as a high-performance NIDS:**

- *Description: Snort passively monitors network traffic with higher throughput using the default DAQ (typically afpacket on Linux). It is suitable for production-like deployments where traffic volumes are higher, but Snort still only alerts or logs without blocking packets.*
- *Command: `sudo snort -A console -q -c /etc/snort/snort.conf -i enp0s3`*
- *Explanation: The default DAQ (afpacket) provides better performance than PCAP. Snort runs as a passive sensor, ideal for observing attacks or network anomalies without affecting normal network operations.*

- **Snort as an inline Network-based IPS (NIPS):**

- *Description: Snort inspects traffic inline between two network interfaces and can actively block malicious packets based on rules. This deployment demonstrates prevention rather than just detection and is used in NIPS configurations.*
- *Command: `sudo snort -Q --daq afpacket -i enp0s3:enp0s8 -c /etc/snort/snort.conf -A console`*
- *Explanation: Inline mode allows Snort to drop or reject packets that match configured rules. AFPacket bridging between interfaces is safer than NFQ for demos, as it avoids host lockouts, and ICMP or other test traffic can be safely blocked to demonstrate prevention.*

NEED FIRST PART OF COMMAND

```
Commencing packet processing (pid=1537)
Decoding Ethernet
10/04-17:32:34.879751  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41796 -> 172.0.0.2:22
10/04-17:32:38.164639  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41810 -> 172.0.0.2:22
10/04-17:32:38.165545  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41820 -> 172.0.0.2:22
10/04-17:32:38.196836  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41820 -> 172.0.0.2:22
10/04-17:32:34.908478  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41792 -> 172.0.0.2:22
10/04-17:32:34.916236  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41786 -> 172.0.0.2:22
10/04-17:32:38.231665  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41810 -> 172.0.0.2:22
10/04-17:32:34.954046  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41796 -> 172.0.0.2:22
^C*** Caught Int-Signal

=====
Run time for packet processing was 33.464954 seconds
Snort processed 372 packets.
Snort ran for 0 days 0 hours 0 minutes 33 seconds
Pkts/sec: 11
10/04-17:32:08.155699  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:33306 -> 172.0.0.2:22
10/04-17:32:08.141226  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:33304 -> 172.0.0.2:22
10/04-17:32:08.185379  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:33314 -> 172.0.0.2:22
=====

Memory usage summary:
Total non-mapped bytes (arena): 7200960
Bytes in mapped regions (hblkhd): 30531584
Total allocated space (wordblks): 5004272
Total free space (fordblks): 2204608
Topmost releasable block (keepcost): 131248
```

```
GUEST student@extrouter:~$ sudo snort -A console -q -c /etc/snort/snort.conf -i enp0s3 --daq pcap
10/04-17:34:11.688413  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41554 -> 172.0.0.2:22
10/04-17:34:14.776703  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41568 -> 172.0.0.2:22
10/04-17:34:14.781138  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41566 -> 172.0.0.2:22
10/04-17:34:14.805397  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41566 -> 172.0.0.2:22
10/04-17:34:14.844251  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41568 -> 172.0.0.2:22
10/04-17:34:11.733388  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41552 -> 172.0.0.2:22
10/04-17:34:17.524399  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41580 -> 172.0.0.2:22
10/04-17:34:17.556851  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41580 -> 172.0.0.2:22
10/04-17:34:14.881030  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41548 -> 172.0.0.2:22
10/04-17:34:18.241649  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41594 -> 172.0.0.2:22
10/04-17:34:18.241648  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41602 -> 172.0.0.2:22
10/04-17:34:18.272642  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41626 -> 172.0.0.2:22
10/04-17:34:18.259582  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41612 -> 172.0.0.2:22
10/04-17:34:18.259800  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41624 -> 172.0.0.2:22
10/04-17:34:18.276018  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41602 -> 172.0.0.2:22
10/04-17:34:18.295670  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41594 -> 172.0.0.2:22
10/04-17:34:18.318541  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41612 -> 172.0.0.2:22
10/04-17:34:18.321736  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41624 -> 172.0.0.2:22
10/04-17:34:18.321738  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41626 -> 172.0.0.2:22
10/04-17:34:15.141570  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41554 -> 172.0.0.2:22
^C*** Caught Int-Signal
10/04-17:34:18.523081  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41552 -> 172.0.0.2:22
10/04-17:34:18.319154  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41568 -> 172.0.0.2:22
10/04-17:34:18.245730  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:41566 -> 172.0.0.2:22
GUEST student@extrouter:~$ sudo snort -A console -q -c /etc/snort/snort.conf -i enp0s3
0/04-17:34:59.022276  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54072 -> 172.0.0.2:22
0/04-17:34:59.032289  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54078 -> 172.0.0.2:22
0/04-17:34:59.030158  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54070 -> 172.0.0.2:22
0/04-17:34:59.054646  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54078 -> 172.0.0.2:22
0/04-17:34:59.043150  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54072 -> 172.0.0.2:22
0/04-17:35:02.077816  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45070 -> 172.0.0.2:22
0/04-17:35:02.098075  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45070 -> 172.0.0.2:22
0/04-17:35:02.398196  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45082 -> 172.0.0.2:22
0/04-17:35:02.419857  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45082 -> 172.0.0.2:22
0/04-17:34:59.123757  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54078 -> 172.0.0.2:22
0/04-17:35:04.203299  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45084 -> 172.0.0.2:22
0/04-17:35:04.232597  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45084 -> 172.0.0.2:22
0/04-17:35:04.883884  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45092 -> 172.0.0.2:22
0/04-17:35:04.908403  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45092 -> 172.0.0.2:22
0/04-17:35:05.767097  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45116 -> 172.0.0.2:22
0/04-17:35:05.761248  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45106 -> 172.0.0.2:22
0/04-17:35:05.786000  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45120 -> 172.0.0.2:22
0/04-17:35:05.786177  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45128 -> 172.0.0.2:22
0/04-17:35:02.462230  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54070 -> 172.0.0.2:22
0/04-17:35:05.789290  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45116 -> 172.0.0.2:22
0/04-17:35:02.488352  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54072 -> 172.0.0.2:22
0/04-17:35:02.495328  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45082 -> 172.0.0.2:22
0/04-17:35:05.821425  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45128 -> 172.0.0.2:22
0/04-17:35:05.828472  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45106 -> 172.0.0.2:22
0/04-17:35:05.845715  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45120 -> 172.0.0.2:22
^C*** Caught Int-Signal
10/04-17:35:05.873046  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54078 -> 172.0.0.2:22
10/04-17:35:05.636834  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:45070 -> 172.0.0.2:22
10/04-17:34:47.302644  [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:40454 -> 172.0.0.2:22
```

```
GUEST student@extrouter:~$ sudo systemctl status snort
● snort.service - Snort NIDS Daemon
   Loaded: loaded (/lib/systemd/system/snort.service; enabled; vendor preset: enabled)
   Active: active (running) since Sat 2025-10-04 17:04:25 UTC; 32min ago
     Main PID: 497 (snort)
       Tasks: 2 (limit: 1111)
      Memory: 73.4M
         CPU: 2.678s
    CGroup: /system.slice/snort.service
            └─497 /usr/local/bin/snort -q -u snort -g snort -c /etc/snort/snort.conf -i enp0s3

Oct 04 17:04:25 extrouter systemd[1]: Started Snort NIDS Daemon.
```

2.3. Logging and Monitoring Snort Alerts

Snort provides multiple methods for logging and monitoring alerts. Describe and provide configuration for three different ways to log and monitor Snort Alerts. For example,

- **Logging alerts to a file:**
 - *Description: Snort can log all alerts to a local file. This is useful for post-analysis and auditing, as you can review alerts even after the IDS has stopped running.*
 - *Command: `sudo tail -f /var/log/snort/alert.log`*
- **Logging alerts to the console:**
 - *Description: Snort can display alerts in real-time on the console. This is useful for immediate monitoring during tests or active defense situations. It shows which traffic triggered a rule as it happens.*
 - *Command: `sudo snort -A console -q -c /etc/snort/snort.conf -i enp0s3`*
 - *Explanation: Alerts will appear directly in the terminal, showing source/destination IPs, ports, and the rule that triggered the alert. This is often used for demonstrations or live monitoring.*
- **Unified2 logging (file-based):**
 - *Description: Snort can log alerts in unified2 format, which is a standardized binary format. It's easier than a database and compatible with tools like Snorby or Sguil if you want later analysis. You don't need to install a database.*
 - *Command: `tail -f /var/log/syslog`*
 - *Explanation: (empty please fill)*

For description - 2-3 sentences per point would be sufficient. You could include one screenshot that shows all three methods or three individual screenshots.

```

GUEST student@extrouter:~$ ls -lh /var/log/snort/
total 13M
drwx----- 2 root root 4.0K Oct 4 12:56 10.0.0.254
drwx----- 2 root root 4.0K Oct 4 12:56 10.0.0.6
-rw-r--r-- 1 root root 3.5M Oct 4 17:53 alert.log
-rw-r--r-- 1 root root 1.3M Oct 4 14:15 alert.log.bak.2025-10-04-14:23:14
-rw----- 1 snort snort 0 Sep 4 2024 snort.log.1725462317
-rw----- 1 snort snort 5.8K Sep 16 2024 snort.log.1726502645
-rw----- 1 snort snort 6.7K Sep 16 2024 snort.log.1726509276
-rw----- 1 snort snort 3.5K Sep 18 2024 snort.log.1726646624
-rw----- 1 snort snort 2.2K Sep 18 2024 snort.log.1726647272
-rw----- 1 snort snort 1.6K Sep 18 2024 snort.log.1726647621
-rw----- 1 snort snort 36K Sep 18 2024 snort.log.1726647729
-rw----- 1 snort snort 1.6K Sep 18 2024 snort.log.1726654957
-rw----- 1 snort snort 1.6K Sep 18 2024 snort.log.1726656373
-rw----- 1 snort snort 5.8K Sep 18 2024 snort.log.1726656453
-rw----- 1 snort snort 4.0K Sep 18 2024 snort.log.1726656779
-rw----- 1 snort snort 7.2K Oct 2 2024 snort.log.1727823714
-rw----- 1 snort snort 2.9K Oct 10 2024 snort.log.1728550862
-rw----- 1 snort snort 9.5K Oct 11 2024 snort.log.1728609466
-rw----- 1 snort snort 3.8K Oct 17 2024 snort.log.1729121514
-rw----- 1 snort snort 1.9K Aug 27 05:06 snort.log.1756270741
-rw----- 1 snort snort 3.5K Aug 27 06:00 snort.log.1756271706
-rw----- 1 snort snort 1.4K Aug 27 06:47 snort.log.1756277228
-rw----- 1 snort snort 2.1K Aug 27 06:59 snort.log.1756277285
-rw----- 1 snort snort 1.6K Aug 27 07:07 snort.log.1756278382
-rw----- 1 snort snort 7.7K Oct 3 16:21 snort.log.1759493717
-rw----- 1 snort snort 2.3K Oct 4 12:06 snort.log.1759579262
-rw----- 1 snort snort 2.9K Oct 4 12:23 snort.log.1759579636
-rw----- 1 snort snort 196 Oct 4 12:40 snort.log.1759580913
-rw----- 1 root root 0 Oct 4 12:41 snort.log.1759581668
-rw----- 1 snort snort 749K Oct 4 13:48 snort.log.1759582187
-rw----- 1 snort snort 368 Oct 4 14:15 snort.log.1759587230
-rw----- 1 root root 0 Oct 4 15:07 snort.log.1759590420
-rw----- 1 snort snort 25K Oct 4 15:19 snort.log.1759590537
-rw----- 1 root root 0 Oct 4 15:18 snort.log.1759591090
-rw----- 1 snort snort 1.4M Oct 4 16:41 snort.log.1759593879
-rw----- 1 root root 216K Oct 4 16:19 snort.log.1759594581
-rw----- 1 root root 1.4K Oct 4 16:19 snort.log.1759594750
-rw----- 1 root root 29K Oct 4 16:20 snort.log.1759594774
-rw----- 1 root root 1.4K Oct 4 16:20 snort.log.1759594804
-rw----- 1 root root 2.5K Oct 4 16:20 snort.log.1759594819
-rw----- 1 root root 3.3K Oct 4 16:20 snort.log.1759594846
-rw----- 1 root root 0 Oct 4 16:21 snort.log.1759594868
-rw----- 1 root root 366 Oct 4 16:37 snort.log.1759595829
-rw----- 1 root root 0 Oct 4 16:37 snort.log.1759595851
-rw----- 1 snort snort 580 Oct 4 16:42 snort.log.1759596105
-rw----- 1 snort snort 1.2M Oct 4 17:04 snort.log.1759596173
-rw----- 1 root root 0 Oct 4 16:44 snort.log.1759596242
-rw----- 1 root root 24K Oct 4 16:51 snort.log.1759596675
-rw----- 1 root root 594 Oct 4 16:51 snort.log.1759596698
-rw----- 1 root root 0 Oct 4 16:55 snort.log.1759596954
-rw----- 1 root root 1.7K Oct 4 16:58 snort.log.1759597081
-rw----- 1 root root 366 Oct 4 17:03 snort.log.1759597378
-rw----- 1 root root 366 Oct 4 17:03 snort.log.1759597390
-rw----- 1 snort snort 3.1M Oct 4 17:53 snort.log.1759597465
-rw----- 1 root root 26K Oct 4 17:05 snort.log.1759597492
-rw----- 1 root root 45K Oct 4 17:07 snort.log.1759597565
-rw----- 1 root root 529K Oct 4 17:17 snort.log.1759597729
-rw----- 1 root root 26K Oct 4 17:20 snort.log.1759598384
-rw----- 1 root root 5.3K Oct 4 17:29 snort.log.1759598960
-rw----- 1 root root 4.2K Oct 4 17:30 snort.log.1759598988
-rw----- 1 root root 11K Oct 4 17:31 snort.log.1759599053
-rw----- 1 root root 8.2K Oct 4 17:31 snort.log.1759599080
-rw----- 1 root root 8.2K Oct 4 17:32 snort.log.1759599127
-rw----- 1 root root 21K Oct 4 17:34 snort.log.1759599237
-rw----- 1 root root 25K Oct 4 17:35 snort.log.1759599269
-rw----- 1 root root 0 Oct 4 17:40 snort.log.1759599644
-rw----- 1 root root 3.4K Oct 4 17:45 snort.log.1759599930
-rw----- 1 root root 194K Oct 4 17:52 snort.log.1759600147
-rw----- 1 root root 54K Oct 4 17:53 snort.log.1759600371

```

```

GUEST student@extrouter:~$ sudo tail -f /var/log/snort/alert.log
10/04-17:45:09.727942 172.0.0.100:32894 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:46520 IpLen:20 DgmLen:700 DF
***AP*** Seq: 0xAD82F667 Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:45:14.024103 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:54600 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:3616 ECHO

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:45:15.051385 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:54635 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:3617 ECHO

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:45:16.052960 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:54741 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:3618 ECHO

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:45:17.055149 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:54770 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:3619 ECHO

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:45:18.057170 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:54810 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:3620 ECHO

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-17:45:18.049891 172.0.0.100:48784 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:63178 IpLen:20 DgmLen:228 DF
***AP*** Seq: 0xD09A03ED Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-17:45:16.490907 172.0.0.100:32894 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:46522 IpLen:20 DgmLen:700 DF
***AP*** Seq: 0xAD82F8EF Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:45:19.058460 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:54818 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:3621 ECHO

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:45:20.060210 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:55033 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:3622 ECHO

^C
GUEST student@extrouter:~$ sudo snort -A console -q -c /etc/snort/snort.conf -i enp0s3
10/04-17:45:42.961579 [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54156 -> 172.0.0.2:22
10/04-17:45:44.902708 [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54172 -> 172.0.0.2:22
10/04-17:45:44.924424 [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:54172 -> 172.0.0.2:22
^C*** Caught Int-Signal
10/04-17:45:45.412581 [**] [1:1000002:0] Possible SSH Brute Force Attack [**] [Priority: 0] {TCP} 172.0.0.100:44994 -> 172.0.0.2:22

```


2.4. Detecting Risks and Attacks using Snort

RULES.CONF NEEDED

ICMP (Ping) reconnaissance / flood

ICMP echo requests are commonly used for simple network discovery and health checks, but excessive or unusual ICMP traffic can indicate reconnaissance or be the start of an ICMP-based DoS. In the lab I used a broad ICMP alert rule so Snort logs any ICMP packets to the monitored network — this quickly highlights scanning and high-volume ping activity so operators can investigate and rate-limit or block the source. Detecting ICMP early reduces the chance an attacker can map the network or saturate links and hosts.

SSH brute-force

SSH brute-force attacks attempt many username/password combinations to gain remote access; successful attacks lead to account compromise and full system takeover while unsuccessful attacks still create noisy logs and can strain authentication services. Snort detects this behaviour with a rule that watches TCP traffic to port 22 and uses a frequency/detection filter (e.g., X attempts within Y seconds) to generate an alert when a single source repeatedly targets SSH, which allows automated or operator responses (block, throttle, or add to Fail2Ban). This detection is critical because it provides a fast, actionable signal to stop credential-based compromise before it succeeds.

SYN flood / TCP connection-flood (SYN attack)

A SYN attack floods a server with TCP SYN packets to consume connection resources or exhaust state table capacity, causing legitimate connection attempts to fail and potentially degrading or denying service. Snort detects abnormal SYN patterns by matching high rates of SYNs to target ports (or via preprocessor/threshold rules) and raises alerts when thresholds are exceeded, enabling immediate mitigation such as SYN rate-limiting, connection queue tuning, or blocking of offending IPs. Identifying SYN floods quickly helps keep critical services available and supports network-level mitigations that stop the attack before it overwhelms servers

```
GUEST student@host: $ ping 172.0.0.1
PING 172.0.0.1 (172.0.0.1) 56(84) bytes of data.
64 bytes from 172.0.0.1: icmp_seq=1 ttl=63 time=48.2 ms
64 bytes from 172.0.0.1: icmp_seq=2 ttl=63 time=2.08 ms
64 bytes from 172.0.0.1: icmp_seq=3 ttl=63 time=1.91 ms
64 bytes from 172.0.0.1: icmp_seq=4 ttl=63 time=2.18 ms
64 bytes from 172.0.0.1: icmp_seq=5 ttl=63 time=1.51 ms
64 bytes from 172.0.0.1: icmp_seq=6 ttl=63 time=50.8 ms
```

```
GUEST student@extrouter:~$ sudo tail -f /var/log/snort/alert.log
10/04-17:59:31.374619 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:31449 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:4465 ECHO

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:59:32.397496 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:31501 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:4466 ECHO

[**] [1:1000001:0] ICMP Traffic Detected [**]
[Priority: 0]
10/04-17:59:33.435431 172.1.0.5 -> 172.0.0.1
ICMP TTL:63 TOS:0x0 ID:31506 IpLen:20 DgmLen:84 DF
Type:8 Code:0 ID:64920 Seq:4467 ECHO
```

```
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-04 14:00:42
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting. ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 5100 login tries (l1/p:5100), ~319 tries per task
[DATA] attacking ssh://172.0.0.2:22/
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "" - 1 of 5100 [child 0] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<!DOCTYPE html>" - 2 of 5100 [child 1] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<html" - 3 of 5100 [child 2] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass " lang=en" - 4 of 5100 [child 3] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass " " - 5 of 5100 [child 4] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "data-color-mode=auto" data-light-theme=light" data-dark-theme=dark" - 6 of 5100 [child 5] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "data-ally-activated-images=system" data-ally-link-underlines=true" - 7 of 5100 [child 6] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "data-css-features=one-click-merge-conflict" - 8 of 5100 [child 7] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass ">" - 9 of 5100 [child 8] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<head>" - 10 of 5100 [child 9] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<meta charset=utf-8>" - 11 of 5100 [child 10] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link rel=dns-prefetch href=https://github.githubassets.com>" - 12 of 5100 [child 11] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link rel=dns-prefetch href=https://avatars.githubusercontent.com>" - 13 of 5100 [child 12] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link rel=dns-prefetch href=https://github-cloud.s3.amazonaws.com>" - 14 of 5100 [child 13] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link rel=dns-prefetch href=https://user-images.githubusercontent.com>" - 15 of 5100 [child 14] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link rel=preconnect href=https://github.githubassets.com crossorigin=" - 16 of 5100 [child 15] (0/0)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link rel=preconnect href=https://avatars.githubusercontent.com>" - 17 of 5100 [child 0] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link crossorigin=anonymous media=all rel=stylesheet href=https://github.githubassets.com/assets/light-6215e264aa81.css" /><link crossorigin=anon"
f 5101 [child 2] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<link crossorigin=anonymous media=all rel=stylesheet href=https://github.githubassets.com/assets/dark-be3560533a2e.css" /><link
f 5101 [child 3] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "ark_high_contrast-0f500fc95568.css" /><link data-color-theme=light crossorigin=anonymous media=all rel=stylesheet data-href=https://github.githu
f 5101 [child 6] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "anonymous media=all rel=stylesheet data-href=https://github.githubassets.com/assets/light_high_contrast-0d1726fbc5ce.css" /><link data-color-theme=
f 5101 [child 7] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "hubassets.com/assets/light_colorblind-295e85c7ac3.css" /><link data-color-theme=light_colorblind_high_contrast crossorigin=anonymous media=all rel=
f 5101 [child 14] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "2e376.css" /><link data-color-theme=light_tritanopia crossorigin=anonymous media=all rel=stylesheet data-href=https://github.githubassets.com/asse
f 5101 [child 0] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "sorigin=anonymous media=all rel=stylesheet data-href=https://github.githubassets.com/assets/light_tritanopia_high_contrast-9be09d7c543a.css" /><link
f 5101 [child 9] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "hub.githubassets.com/assets/dark-be3560533a2e.css" /><link data-color-theme=dark_high_contrast crossorigin=anonymous media=all rel=stylesheet" data-
f 5101 [child 10] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "theme=dark_colorblind crossorigin=anonymous media=all rel=stylesheet data-href=https://github.githubassets.com/assets/dark_colorblind-b93c131e97d
f 5101 [child 11] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "rel=stylesheet data-href=https://github.githubassets.com/assets/dark_colorblind_high_contrast-562d56be7ab1.css" /><link data-color-theme=dark_tritanopia
f 5101 [child 12] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "ssets/dark_tritanopia-297cb06a83c5.css" /><link data-color-theme=dark_tritanopia_high_contrast crossorigin=anonymous media=all rel=stylesheet" data-
f 5101 [child 8] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "data-color-theme=dark_dimmed crossorigin=anonymous media=all rel=stylesheet data-href=https://github.githubassets.com/assets/dark_dimmed-64c3ca7d
f 5101 [child 13] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "el=stylesheet data-href=https://github.githubassets.com/assets/dark_dimmed_high_contrast-89581edef127.css" />" - 31 of 5101 [child 1] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "<style type=text/css>" - 32 of 5101 [child 9] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "root {" - 33 of 5101 [child 4] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "--tab-size-preference: 4;" - 34 of 5101 [child 2] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "}" - 35 of 5101 [child 3] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "pre, code {" - 36 of 5101 [child 6] (0/1)
[ATTEMPT] target 172.0.0.2 - login "extrouter" - pass "tab-size: var(--tab-size-preference);" - 37 of 5101 [child 14] (0/1)
```

```
GUEST student@extrouter:~$ sudo tail -f /var/log/snort/alert.log
10/04-18:01:51.285829 172.0.0.100:60274 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:26333 IpLen:20 DgmLen:700 DF
***AP*** Seq: 0xEBE2CE19 Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:51.281511 172.0.0.100:40034 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:51769 IpLen:20 DgmLen:492 DF
***AP*** Seq: 0xB9D1E48D Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:54.574743 172.0.0.100:39918 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:10894 IpLen:20 DgmLen:404 DF
***AP*** Seq: 0xBA1CEC1E Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:54.596812 172.0.0.100:39948 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:59776 IpLen:20 DgmLen:452 DF
***AP*** Seq: 0x193DB87A Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:54.614898 172.0.0.100:39992 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:10440 IpLen:20 DgmLen:540 DF
***AP*** Seq: 0xAC899933 Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:54.585515 172.0.0.100:39976 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:53276 IpLen:20 DgmLen:452 DF
***AP*** Seq: 0xB1C6E1E5 Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:54.585492 172.0.0.100:39970 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:65205 IpLen:20 DgmLen:404 DF
***AP*** Seq: 0xDB89093A Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:54.636361 172.0.0.100:39940 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:41125 IpLen:20 DgmLen:452 DF
***AP*** Seq: 0xCB8D977B Ack: 0x0 Win: 0x0 TcpLen: 32

[**] [1:1000002:0] Possible SSH Brute Force Attack [**]
[Priority: 0]
10/04-18:01:54.648029 172.0.0.100:39980 -> 172.0.0.2:22
TCP TTL:64 TOS:0x0 ID:621 IpLen:20 DgmLen:508 DF
***AP*** Seq: 0x16A97B80 Ack: 0x0 Win: 0x0 TcpLen: 32
```



```
nmap -sS -p 1-200 172.0.0.2

Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-10-04 14:08 EDT
Nmap scan report for 172-0-0-2.lightspeed.brhmal.sbcglobal.net (172.0.0.2)
Host is up (0.0013s latency).
Not shown: 199 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:A9:06:CB (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 12.53 seconds
```

```
$ sudo nmap -A console -q -c /etc/snort/snort.conf --ip-opts=--ttl=60 --log-hostname
```

	studentBriouter:	sudonort-A	console-q-c/etc/snort/snort.conf	--ip-opts=--ttl=60	--log-hostname	-dqa packetset
10/04-18:09:06.688127	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:191
10/04-18:09:06.688128	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:55
10/04-18:09:06.688283	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:56
10/04-18:09:06.688284	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:28
10/04-18:09:06.688285	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:130
10/04-18:09:06.688285	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:90
10/04-18:09:06.688286	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:156
10/04-18:09:06.688287	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:114
10/04-18:09:06.688288	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:65
10/04-18:09:06.688288	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:72
10/04-18:09:06.688288	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:71
10/04-18:09:06.690914	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:1
10/04-18:09:06.690915	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:40
10/04-18:09:06.690916	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:112
10/04-18:09:06.690916	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:99
10/04-18:09:06.691987	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:118
10/04-18:09:06.691987	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:178
10/04-18:09:06.691988	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:11
10/04-18:09:06.691988	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:4
10/04-18:09:06.691989	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:158
10/04-18:09:06.691990	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:84
10/04-18:09:06.693045	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:127
10/04-18:09:06.693046	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:93
10/04-18:09:06.693047	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:186
10/04-18:09:06.693048	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:13
10/04-18:09:06.695007	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:179
10/04-18:09:06.695008	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:20
10/04-18:09:06.695009	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:133
10/04-18:09:06.695009	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:151
10/04-18:09:06.695010	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:142
10/04-18:09:06.695011	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:8
10/04-18:09:06.695012	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:100
10/04-18:09:06.696999	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:8
10/04-18:09:06.696999	**	[*:]:[1:000005:-]	Possible TCP SYN Scan**	(Priority: 0)	TCP	172.0.0.100:44321-> 172.0.0.2:152
10/04-18:09:06.696999	**	[*:]:[1:000005:-]	Possible TCP SYN Scan			

2.5. Complementary Controls for IDS

Complementary control 1 — Firewall rate-limiting and filtering

A host/network firewall configured with targeted rate-limiting and packet-filtering rules provides immediate, preventive protection by dropping or throttling malicious traffic before it reaches vulnerable services. For example, ICMP rate limits reduce the impact of ping floods, SYN/connection limits reduce the effect of simple DoS and connection-flood attacks, and SSH connection-rate rules reduce the ability of an attacker to try many logins per second. This control complements Snort by acting on detection — Snort alerts can trigger automated firewall actions or operator review while the firewall enforces real-time mitigation to keep services available.

Complementary control 2 — Authentication hardening and automated logout (Fail2Ban)

Hardening authentication (disable password auth, require SSH keys, disable root login) combined with an automated logout tool such as Fail2Ban greatly reduces the chance that brute-force attempts succeed and quickly removes repeat offenders from the network. Fail2Ban watches logs (e.g., /var/log/auth.log or alert.log) and adds temporary firewall bans for IPs that exceed configured failure thresholds, stopping brute-force and repeated Snort-detected offenders automatically. Together with Snort's detection capabilities, this approach gives defence-in-depth: Snort alerts identify suspicious behaviour while authentication hardening prevents compromise and Fail2Ban enforces fast, automated blocking.

3. Portfolio 3

3.1. Main purposes of Proxy

Explain, in terms of security goals (CIA) and security principles, the main purposes of the two proxy configurations that were demonstrated in this tutorial. Please note the security goals and principles need to be aligned with the two proxy configurations that are shown in the tutorial.

The tutorial demonstrated two proxy configurations: a forward proxy and a reverse proxy. Each configuration serves a distinct purpose and aligns with different security goals (Confidentiality, Integrity, and Availability) and security principles.

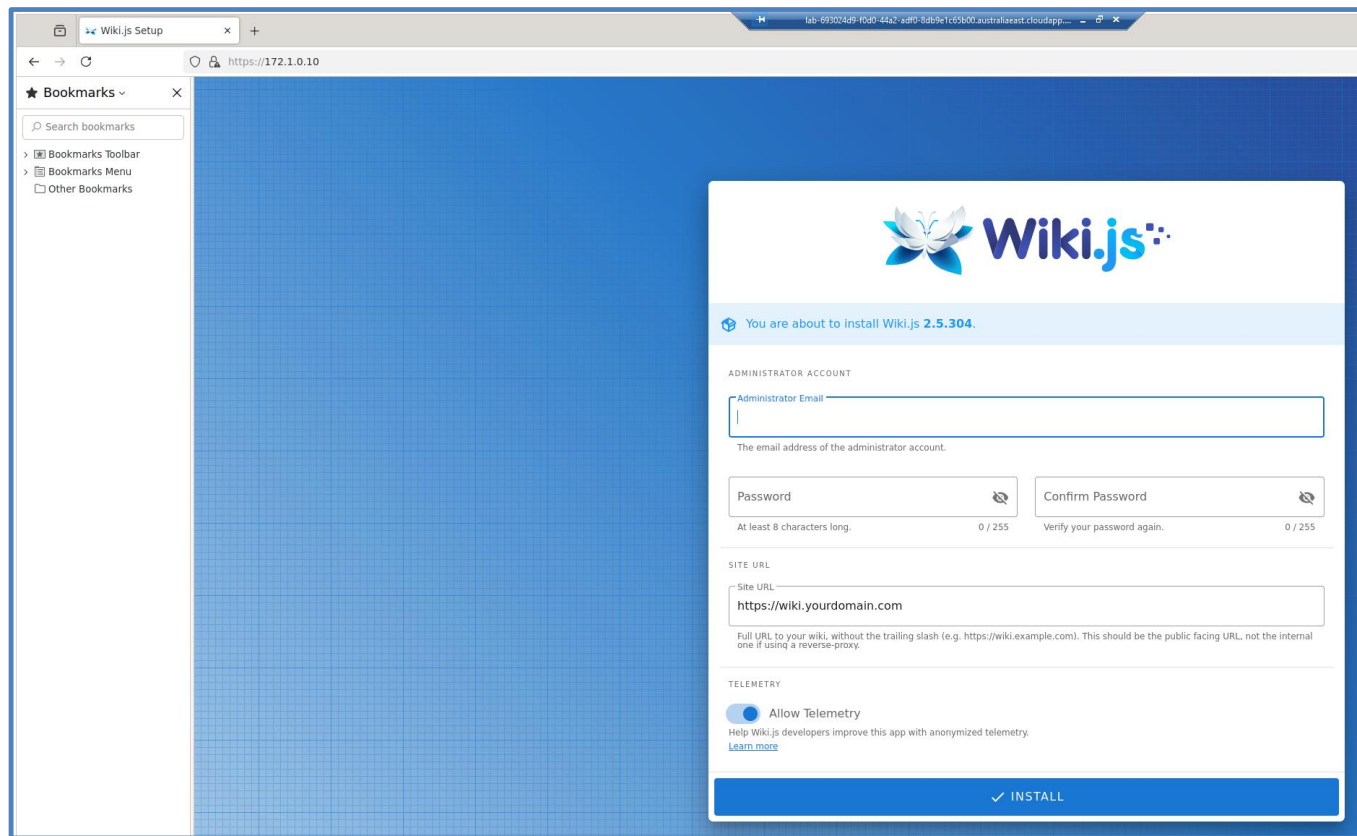
Forward Proxy Configuration

The forward proxy acts as an intermediary between internal users and external websites. Its primary security goal is Confidentiality, as it hides the client's internal IP address and network structure from the internet, reducing exposure to external threats. It also supports Integrity by filtering outbound requests to prevent access to malicious sites and block unwanted content. This configuration aligns with the security principles of Least Privilege (restricting direct access to external networks) and Defence in Depth, by adding an additional security layer before traffic leaves the internal network.

Reverse Proxy Configuration

The reverse proxy sits in front of a web server, receiving incoming client requests before they reach the server. Its main security goal is Availability and Confidentiality, as it prevents direct access to the internal web server, concealing its IP address and protecting it from direct attacks such as DDoS or port scanning. It also enhances Integrity by handling SSL/TLS encryption, ensuring secure communication between clients and the proxy. This configuration supports the security principles of Fail-Safe Defaults (denying direct server access by default) and Separation of Duties (offloading authentication and encryption handling to the proxy).

Add the 5 screenshots mentioned in the tutorial with relevant captions. Please note screenshots need to be clear and must have caption.



The image displays a Wireshark packet capture of a TLSv1.3 connection. The packet list on the left shows the following packets:

- 7: 0.114843360 → 172.0.0.100 → 35.190.72.216: TCP 76 55126 → 443 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=4218022080 TSecr=0 WS=128
- 8: 0.146774011 → 35.190.72.216 → 172.0.0.100: TCP 76 443 → 55126 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1412 SACK_PERM TSval=2007293563 TSecr=4218022080 WS=256
- 9: 0.116852899 → 172.0.0.100 → 35.190.72.216: TLSv1.3 68 55126 → 443 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=4218022082 TSecr=2007293563
- 10: 0.160699373 → 35.190.72.216 → 172.0.0.100: TLSv1.3 585 Client Hello (SN=location.services.mozilla.com)
- 11: 0.162671520 → 35.190.72.216 → 172.0.0.100: TCP 68 443 → 55126 [ACK] Seq=1 Ack=518 Win=268288 Len=0 TSval=2007293609 TSecr=4218022126
- 12: 0.165236898 → 35.190.72.216 → 172.0.0.100: TLSv1.3 3155 Server Hello, Change Cipher Spec, Application Data
- 13: 0.165293732 → 172.0.0.100 → 35.190.72.216: TCP 68 55126 → 443 [ACK] Seq=518 Ack=3088 Win=31872 Len=0 TSval=4218022131 TSecr=2007293611
- 14: 0.271040921 → 172.0.0.100 → 35.190.72.216: TLSv1.3 132 Change Cipher Spec, Application Data
- 15: 0.273612407 → 35.190.72.216 → 172.0.0.100: TLSv1.3 686 Application Data, Application Data
- 16: 0.273774690 → 172.0.0.100 → 35.190.72.216: TCP 68 55126 → 443 [ACK] Seq=582 Ack=3706 Win=31872 Len=0 TSval=4218022239 TSecr=2007293720
- 17: 0.594956048 → 172.0.0.100 → 35.190.72.216: TLSv1.3 238 Application Data
- 18: 0.595591319 → 172.0.0.100 → 35.190.72.216: TLSv1.3 294 Application Data
- 19: 0.595874602 → 172.0.0.100 → 35.190.72.216: TLSv1.3 99 Application Data
- 20: 0.596937601 → 35.190.72.216 → 172.0.0.100: TLSv1.3 99 Application Data
- 21: 0.597043947 → 172.0.0.100 → 35.190.72.216: TCP 68 55126 → 443 [ACK] Seq=1009 Ack=3737 Win=31872 Len=0 TSval=4218022562 TSecr=2007294043
- 22: 0.598196936 → 35.190.72.216 → 172.0.0.100: TCP 68 443 → 55126 [ACK] Seq=3737 Ack=1009 Win=268800 Len=0 TSval=2007294044 TSecr=4218022561
- 23: 0.755633368 → 35.190.72.216 → 172.0.0.100: TLSv1.3 253 Application Data
- 24: 0.755633703 → 35.190.72.216 → 172.0.0.100: TLSv1.3 147 Application Data
- 25: 0.755633782 → 35.190.72.216 → 172.0.0.100: TLSv1.3 107 Application Data
- 26: 0.755633849 → 35.190.72.216 → 172.0.0.100: TCP 107 [TCP Retransmission] 443 → 55126 [PSH, ACK] Seq=4001 Ack=1009 Win=268800 Len=39 TSval=2007294192 TSecr=4218022562
- 27: 0.756293189 → 172.0.0.100 → 35.190.72.216: TCP 68 55126 → 443 [ACK] Seq=1009 Ack=3922 Win=31872 Len=0 TSval=4218022721 TSecr=2007294185
- 28: 0.756297968 → 172.0.0.100 → 35.190.72.216: TCP 68 55126 → 443 [ACK] Seq=1009 Ack=4001 Win=31872 Len=0 TSval=4218022722 TSecr=2007294185
- 29: 0.756391836 → 172.0.0.100 → 35.190.72.216: TCP 68 55126 → 443 [ACK] Seq=1009 Ack=4040 Win=31872 Len=0 TSval=4218022722 TSecr=2007294185
- 30: 0.756328438 → 172.0.0.100 → 35.190.72.216: TCP 80 [TCP Dup ACK 29#1] 55126 → 443 [ACK] Seq=1009 Ack=4040 Win=31872 Len=0 TSval=4218022722 TSecr=2007294192 SLE=4001 SRE=4040
- 31: 0.758786210 → 172.0.0.100 → 35.190.72.216: TLSv1.3 187 Application Data
- 32: 0.765098173 → 35.190.72.216 → 172.0.0.100: TCP 68 443 → 55126 [ACK] Seq=4040 Ack=1048 Win=268800 Len=0 TSval=2007294212 TSecr=4218022724
- 33: 0.687958428 → 172.0.0.100 → 35.190.72.216: TLSv1.3 187 Application Data
- 34: 0.688940559 → 35.190.72.216 → 172.0.0.100: TCP 68 443 → 55126 [ACK] Seq=4040 Ack=1087 Win=268800 Len=0 TSval=2007295136 TSecr=4218023652
- 35: 0.688943422 → 35.190.72.216 → 172.0.0.100: TLSv1.3 187 Application Data
- 44: 0.739532179 → 172.0.0.100 → 35.190.72.216: TCP 68 55126 → 443 [ACK] Seq=1087 Ack=4079 Win=31872 Len=0 TSval=4218023705 TSecr=2007295136

The packet details pane on the right shows the structure of the selected packet (Packet 23):

- Frame 18: 294 bytes on wire (2352 bits), 294 bytes captured (2352 bits) on interface any, id 0
- Linux cooked capture v1
- Internet Protocol Version 4, Src: 172.0.0.100, Dst: 35.190.72.216
- Transmission Control Protocol, Src Port: 55126, Dst Port: 443, Seq: 752, Ack: 3706, Len: 226
- Transport Layer Security
 - TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol
 - Opaque Type: Application Data (23)
 - Version: TLS 1.2 (0x0303)
 - Length: 221
 - Encrypted Application Data [truncated]: 41f9d0e6db845e732d180a9e6c1b681ca4bb8b54e339cd3e749aeca4c7f...

tcp.port==3000

No.	Time	Source	Destination	Protocol	Length	Info
2218	65.777615378	172.0.0.100	172.1.0.10	TCP	76	58850 → 3000 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=4211640791 TSecr=0 WS=128
2220	65.784081151	172.0.0.100	172.1.0.10	TCP	76	58864 → 3000 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=4211640797 TSecr=0 WS=128
2222	65.785115773	172.1.0.10	172.0.0.100	TCP	76	3000 → 58850 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3773841296 TSecr=4211640791 WS=128
2223	65.785369059	172.0.0.100	172.1.0.10	TCP	68	58850 → 3000 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=4211640798 TSecr=3773841296
2224	65.786354887	172.1.0.10	172.0.0.100	TCP	76	3000 → 58864 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3773841299 TSecr=4211640797 WS=128
2225	65.786596750	172.0.0.100	172.1.0.10	TCP	68	58864 → 3000 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=4211640800 TSecr=3773841299
2226	65.793722298	172.0.0.100	172.1.0.10	HTTP	407	GET / HTTP/1.1
2227	65.796777785	172.1.0.10	172.0.0.100	TCP	68	3000 → 58850 [ACK] Seq=1 Ack=340 Win=64896 Len=0 TSval=3773841310 TSecr=4211640807
2228	66.523896858	172.1.0.10	172.0.0.100	TCP	367	3000 → 58850 [PSH, ACK] Seq=1 Ack=340 Win=64896 Len=299 TSval=3773842031 TSecr=4211640807 [TCP segment of a reassembled PDU]
2229	66.524375965	172.0.0.100	172.1.0.10	TCP	68	58850 → 3000 [ACK] Seq=340 Ack=300 Win=31872 Len=0 TSval=4211641538 TSecr=3773842031
2230	66.533971598	172.1.0.10	172.0.0.100	TCP	645	3000 → 58850 [PSH, ACK] Seq=300 Ack=340 Win=64896 Len=577 TSval=3773842047 TSecr=4211641538 [TCP segment of a reassembled PDU]
2231	66.534065214	172.0.0.100	172.1.0.10	TCP	68	58850 → 3000 [ACK] Seq=340 Ack=877 Win=31360 Len=0 TSval=4211641547 TSecr=3773842047
2232	66.536403544	172.1.0.10	172.0.0.100	HTTP	73	HTTP/1.1 200 OK (text/html)
2233	66.536452514	172.0.0.100	172.1.0.10	TCP	68	58850 → 3000 [ACK] Seq=340 Ack=882 Win=31360 Len=0 TSval=4211641550 TSecr=3773842050
2241	68.482908407	172.0.0.100	172.1.0.10	HTTP	386	GET /assets/css/setup.36d0e9e9a95efda073aa.css HTTP/1.1
2242	68.483267597	172.0.0.100	172.1.0.10	HTTP	361	GET /assets/js/runtime.js?1726622198 HTTP/1.1
2243	68.485808797	172.1.0.10	172.0.0.100	TCP	68	3000 → 58864 [ACK] Seq=1 Ack=319 Win=64896 Len=0 TSval=3773844000 TSecr=4211643496
2244	68.485809416	172.1.0.10	172.0.0.100	TCP	68	3000 → 58850 [ACK] Seq=882 Ack=633 Win=64640 Len=0 TSval=3773844000 TSecr=4211643497
2245	68.485843060	172.0.0.100	172.1.0.10	TCP	76	58878 → 3000 [SYN] Seq=0 Win=32120 Len=0 MSS=1460 SACK_PERM TSval=4211643499 TSecr=0 WS=128
2246	68.489347237	172.1.0.10	172.0.0.100	TCP	76	3000 → 58878 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=3773844003 TSecr=4211643499 WS=128
2247	68.489597366	172.0.0.100	172.1.0.10	TCP	68	58878 → 3000 [ACK] Seq=1 Ack=1 Win=32128 Len=0 TSval=4211643503 TSecr=3773844003
2248	68.494041700	172.0.0.100	172.1.0.10	HTTP	359	GET /assets/js/setup.js?1726622198 HTTP/1.1
2249	68.495266836	172.1.0.10	172.0.0.100	TCP	68	3000 → 58878 [ACK] Seq=1 Ack=292 Win=64896 Len=0 TSval=3773844010 TSecr=4211643507
2250	68.618222423	172.1.0.10	172.0.0.100	TCP	454	3000 → 58864 [PSH, ACK] Seq=1 Ack=319 Win=64896 Len=386 TSval=3773844132 TSecr=4211643496 [TCP segment of a reassembled PDU]
2251	68.618667306	172.0.0.100	172.1.0.10	TCP	68	58864 → 3000 [ACK] Seq=319 Ack=387 Win=31872 Len=0 TSval=4211643632 TSecr=3773844132
2252	68.632173298	172.1.0.10	172.0.0.100	TCP	467	3000 → 58850 [PSH, ACK] Seq=882 Ack=633 Win=64640 Len=399 TSval=3773844144 TSecr=4211643497 [TCP segment of a reassembled PDU]
2253	68.632752495	172.0.0.100	172.1.0.10	TCP	68	58850 → 3000 [ACK] Seq=633 Ack=1281 Win=30976 Len=0 TSval=4211643646 TSecr=3773844144
2254	68.641861460	172.1.0.10	172.0.0.100	TCP	2255	3000 → 58850 [PSH, ACK] Seq=1281 Ack=633 Win=64640 Len=2187 TSval=3773844156 TSecr=4211643646 [TCP segment of a reassembled PDU]
2255	68.642035359	172.0.0.100	172.1.0.10	TCP	68	58850 → 3000 [ACK] Seq=633 Ack=3468 Win=31872 Len=0 TSval=4211643655 TSecr=3773844156
2256	68.643617657	172.1.0.10	172.0.0.100	HTTP	73	HTTP/1.1 200 OK (application/javascript)

Frame 2218: 76 bytes on wire (608 bits), 76 bytes captured (608 bits) on interface any, id 0

Linux cooked capture v1

Internet Protocol Version 4, Src: 172.0.0.100, Dst: 172.1.0.10

Transmission Control Protocol, Src Port: 58850, Dst Port: 3000, Seq: 0, Len: 0

0000 00 04 00 01 00 06 08 00 27 9c 0f 2c e1 52 08 00 , R...

0010 45 00 00 3c 0a 03 40 00 40 06 d8 49 ac 00 00 64 E...<.@.@.I..d

0020 ac 01 00 0a e5 e2 0b b8 11 68 31 54 00 00 00 00 hIT.....

0030 a0 02 7d 78 58 9e 00 00 02 04 05 b4 04 02 08 0a ...}xX.....

0040 fb 08 89 d7 00 00 00 00 01 03 03 07

https://debian.org/	GET	302	0	72ms
http://172.1.0.20:8081/static/images/resourceRedirectIcon.png	GET	200	1.1kb	32ms
https://www.debian.org/	GET	200	4.1kb	51ms
https://www.debian.org/debhome.css	GET	200	1.5kb	192ms
https://www.debian.org/startpage.css	GET	200	2.7kb	263ms
https://www.debian.org/Simg-carousel-slider.css	GET	200	1.3kb	124ms
https://www.debian.org/debian-en.css	GET	200	350b	107ms
https://www.debian.org/Pics/openlogo-50.png	GET	200	2.0kb	111ms
https://www.debian.org/Pics/debconf25_group_photo.jpg	GET	200	507.7kb	2s
https://www.debian.org/Pics/mini-dc25-hamburg.jpg	GET	200	431.0kb	1s
https://www.debian.org/Pics/mini-dc25-maceio.jpg	GET	200	151.1kb	994ms
https://www.debian.org/Pics/calamares-installer.png	GET	200	275.5kb	1s
https://www.debian.org/Pics/debian-swiss-knife-hands-1024x576.jpg	GET	200	118.4kb	892ms
https://www.debian.org/Pics/debian-funny-people-1024x576.jpg	GET	200	214.2kb	1s
https://www.debian.org/Pics/users.svg	GET	200	3.4kb	338ms
https://www.debian.org/Pics/heartbeat.svg	GET	200	2.3kb	335ms
https://www.debian.org/Pics/user-plus.svg	GET	200	2.9kb	335ms
https://www.debian.org/Pics/list.svg	GET	200	2.5kb	170ms
https://www.debian.org/Pics/debian-logo-1024x576.png	GET	200	32.0kb	314ms
https://www.debian.org/Pics/trophy.svg	GET	200	2.8kb	169ms
https://www.debian.org/Pics/life-ring.svg	GET	200	3.1kb	168ms
https://www.debian.org/Pics/security.svg	GET	200	2.1kb	173ms
https://www.debian.org/debian.css	GET	200	4.6kb	70ms
https://www.debian.org/empty.css	GET	200	0	46ms
https://www.debian.org/Pics/ceratopsian-fg.svg	GET	200	22.7kb	89ms
https://www.debian.org/avicon.ico	GET	200	5.8kb	57ms
http://172.1.0.20:8081/flows/4ad4b28b-5064-4c39-9ae6-942cdf16a8f9/request/content/Auto.json?lines=513	GET	200	42b	21ms

www.reddit.com/r/memes/

☆

↓

Kali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

Looks like there’s a problem with this site

https://www.reddit.com/r/memes/ sent back an error.

Error code: 403 Forbidden

• Check to make sure you’ve typed the website address correctly.

Try Again

InspectorConsoleDebuggerNetworkStyle EditorPerformanceMemoryStorageAccessibilityApplication

Filter URLs

||+🔍

AllHTMLCSSJSXHRFontsImagesMediaWSOther

☐ Disable Cache

No Throttling

⚙

Status	Method	Domain	File	Initiator	Type	Transferred	Size	0 ms	40 ms	80 ms	160 ms	240 ms	320 ms	400 ms
403	GET	www.reddit.com	/r/memes/	document	plain	80 B	0 B	36 ms						

3.2. Remaining Risk

For each of the two proxy configurations, name and explain two or three risks that remain after deploying (5 in total). 2-3 sentences for each risk explanation should be enough.

Although the proxy configurations enhance network security, several residual risks remain after deployment.

1. Weak Password Policy (Forward Proxy)

The proxy authentication uses a basic password mechanism without enforcing strong password complexity. This increases the risk of brute-force attacks and credential compromise.

2. Log Exposure (Forward Proxy)

Proxy access logs may contain sensitive URLs or credentials if transmitted insecurely, creating potential privacy risks if logs are accessed by unauthorised users.

3. Misconfigured SSL Certificates (Reverse Proxy)

If SSL/TLS certificates are not properly configured or renewed, encrypted communication could fail or downgrade to HTTP, compromising confidentiality and integrity.

4. Reverse Proxy Server Exploitation (Reverse Proxy)

The reverse proxy itself can become a target. If vulnerabilities exist in the Nginx service, attackers could exploit it to gain access to backend systems.

5. Lack of Centralised Log Monitoring (Both Configurations)

Although both proxies generate logs, they are not monitored centrally. This delays the detection of anomalies or ongoing attacks across the network.

3.3. Complementary Controls to Proxy

For each risk that you identified, name and explain a complementary control that could be used to further mitigate the risk. 2 to 3 sentences for each control should be enough.

To further reduce the above risks, the following complementary controls are recommended:

1. Enforce Strong Password Policies (Forward Proxy)

Implement a minimum password length, complexity requirements, and account lockout after multiple failed login attempts. This reduces the risk of brute-force attacks.

2. Secure Log Management (Forward Proxy)

Encrypt proxy logs at rest and restrict access to authorised administrators only. Regular log rotation should be implemented to minimise exposure.

3. Certificate Management and Monitoring (Reverse Proxy)

Use automated certificate renewal tools (e.g., Certbot) and enforce strict HTTPS redirection to ensure all communications remain encrypted.

4. Patch Management and Service Hardening (Reverse Proxy)

Keep the Nginx service up to date with the latest security patches. Disable unnecessary modules and enforce minimal privileges for the proxy process.

5. Centralised SIEM Implementation (Both Configurations)

Deploy a Security Information and Event Management (SIEM) system to collect and analyse proxy logs in real time. This allows quicker detection of suspicious activity and improves incident response.

4. Portfolio 4

Details will be found in the corresponding week

4.1. Introduction to SIEM

Provide a brief explanation of SIEM's primary purpose (at least three) and its role in network security. 2-3 sentences for each purpose/ feature should be sufficient.

Primary Purpose 1 – Centralized Log Collection and Management:

SIEM solutions collect and centralize logs from multiple network devices, servers, and endpoints. This allows security teams to have a comprehensive view of the organisation's security events in one place. For example, Wazuh collects logs from all deployed agents, ensuring that events from virtual machines like the extrouter are monitored continuously.

Primary Purpose 2 – Real-Time Event Correlation and Threat Detection:

SIEMs analyze log data in real-time to identify suspicious patterns or potential threats. By correlating events from multiple sources, a SIEM can detect attacks such as network reconnaissance, failed login attempts, or unusual administrative actions. In Wazuh, active monitoring of agents' logs allows alerts to trigger immediately when anomalous activity is detected.

Primary Purpose 3 – Compliance Monitoring and Reporting:

SIEM solutions help organisations meet regulatory and internal compliance requirements by logging security events, generating reports, and maintaining audit trails. Wazuh provides dashboards and reports that document security events, asset inventory, and agent activity, which can be used to verify adherence to security policies and standards.

4.2. Wazuh as SIEM

Briefly describe Wazuh as SIEM and mention what features it provides that support security monitoring and threat management in terms of activities done in this tutorial. 2-3 sentences for each activity would be sufficient. Add the screenshot with the relevant feature.

Feature 1 – Agent Deployment and Log Collection:

Wazuh agents were deployed on multiple virtual machines (e.g., extrouter) to collect logs and transmit them to the Wazuh Manager. This feature enables centralized monitoring of all endpoints, providing insight into system health, network activity, and triggered alerts.

Screenshot: Use the “Endpoint Summary” showing the registered agent(s). Caption: “Figure 2: Wazuh Endpoint Summary showing registered agents.”

Feature 2 – Monitoring and Asset Inventory:

The Inventory section of Wazuh provides detailed information about monitored assets, including network interfaces, open ports, and system configurations. This allows security teams to quickly identify vulnerabilities or misconfigurations in the environment.

Screenshot: Use the extrouter inventory screenshot. Caption: “Figure 3: Inventory details of extrouter showing network interfaces and ports.”

Feature 3 – Threat Intelligence Integration (MITRE ATT&CK):

Wazuh integrates MITRE ATT&CK to map detected events to known adversary tactics, techniques, and procedures (TTPs). This enhances the capability to classify attacks, understand adversary behaviour, and implement appropriate mitigations.

Screenshot: Use one of your MITRE ATT&CK screenshots showing the technique details. Caption: “Figure 4: MITRE ATT&CK technique details integrated with Wazuh.”

Feature 4 – Real-Time Alerts and Detection:

Wazuh can generate real-time alerts based on log analysis and event correlation. For example, detection of unusual network scanning or abnormal login activity is immediately highlighted in the dashboard, enabling fast response.

Screenshot: Any alert from your dashboard showing real-time detection. Caption: “Figure 5: Wazuh alert showing detected suspicious network activity.”

⌕ Search bookmarks

🔖 Bookmarks Toolbar

🔖 Bookmarks Menu

🔖 Other Bookmarks

W. Overview

ADENTS SUMMARY


No results
No results were found.

Critical severity
0
Rule level 10 or higher

High severity
0
Rule level 12 to 16

Medium severity
127
Rule level 7 to 11

Low severity
262
Rule level 2 to 6

LAST 24 HOURS ALERTS

ENDPOINT SECURITY


Configuration Assessment
Scan your assets as part of a configuration assessment audit.


Malware Detection
Verify that your systems are configured according to your security policies baseline.


File Integrity Monitoring
Alerts related to file changes, including permissions, content, ownership, and attributes.

SECURITY OPERATIONS


PCI DSS
Global security standard for entities that process, store, or transmit payment cardholder data.


GDPR
General Data Protection Regulation (GDPR) sets guidelines for processing of personal data.


HIPAA
Health Insurance Portability and Accountability Act of 2006 (HIPAA) provides data privacy and security provisions for safeguarding medical information.


NIST 800-53
National Institute of Standards and Technology Special Publication 800-53 (NIST 800-53) sets guidelines for federal information systems.


TSC
Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy.

THREAT INTELLIGENCE


Threat Hunting
Browse through your security alerts, identifying issues and threats in your environment.


Vulnerability Detection
Discover what applications in your environment are affected by well-known vulnerabilities.


MITRE ATT&CK
Security events from the knowledge base of adversary tactics and techniques based on real-world observations.


VirusTotal
Alerts resulting from VirusTotal analysis of suspicious files via an integration with their API.

CLOUD SECURITY


Docker
Monitor and control running, starting, and stopping containers such as creation.


Amazon Web Services
Security events related to your Amazon AWS services, collected directly via AWS API.


Google Cloud
Security events related to your Google Cloud Platform services, collected directly via GCP API.


GitHub
Monitoring events from audit logs of your GitHub organizations.


Office 365
Security events related to your Office 365 services.

New release is available! Go to the API configuration page for details

☐ Disable updates notifications [Dismiss](#)

[Generate report](#)

 Refresh
 Export formatted

WOLRows per page: 10 ▾

< 1 >

[🔄 Refresh](#) [📄 Export formatted](#)

WOLRows per page: 10 v

< 1 >

[Refresh](#) [Export formatted](#)WOLRows per page: 10

< 1 >

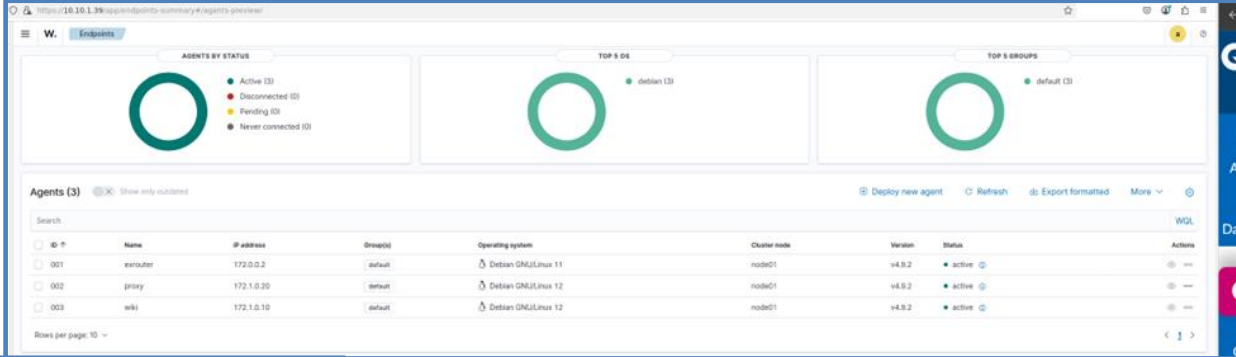
 Rows per page: 10

< 1 2 3 4 5 ... 48 >

[Cl Refresh](#) [/h Export formatted](#)

--	--

Name ^	Effective user	Effective group	PID	Parent PID	Command	Args	VM size	Size	Session	Priority	State
(sd-pam)	student	student	619	617	(sd-pam)		100968	25242	617	0	S
acpi_thermal_pm	root	root	59	2			0	0	0	-20	I
agetty	root	root	500	1	/sbin/agetty	-o -p --lu --noclear tty1 linux	2872	718	500	0	S
ata_sff	root	root	114	2			0	0	0	-20	I
bash	student	student	639	638	-bash		6620	1705	639	0	S
blkcg_punt_bio	root	root	52	2			0	0	0	-20	I
chronyd	._chrony	._chrony	502	1	/usr/sbin/chronyd	-F 1	19028	4757	501	0	S
chronyd	._chrony	._chrony	503	502	/usr/sbin/chronyd	-F 1	10836	2709	501	0	S
cpuhp/0	root	root	15	2			0	0	0	0	S
cpuhp/1	root	root	16	2			0	0	0	0	S

Agents (3) 🔍 Show only outdated

🔗 Deploy new agent 🔄 Refresh 📄 Export formatted More ⚙️

🔍	ID ↑	Name	IP address	Group(s)	Operating system	Cluster node	Version	Status	Actions
	001	router	172.0.0.2	default	Debian GNU/Linux 11	node01	v4.9.2	● active	⋮
	002	proxy	172.1.0.20	default	Debian GNU/Linux 12	node01	v4.9.2	● active	⋮
	003	wiki	172.1.0.10	default	Debian GNU/Linux 12	node01	v4.9.2	● active	⋮

Rows per page: 10

proxy 📄 Generate report

Cores: 2 Memory: 1967.02 MB Arch: x86_64 Operating system: Debian GNU/Linux 12 (bookworm) CPU: Intel(R) Xeon(R) Platinum 8272CL CPU @ 2.60GHz Host name: proxy Board serial: 0 Last scan: Oct 6, 2025 @ 14:19:52.000

Network interfaces (8) 🔄 Refresh 📄 Export formatted

🔍

Name ↑	MAC	State	MTU	Type
br-4242931631b4	02:42:3e:73:60:ff	up	1500	ethernet
br-8674330ab1a	02:42:fc:c0:18:e8	down	1500	ethernet
br-aa44d528d08	02:42:2a:26:5c:cc	up	1500	ethernet
docker0	02:42:4b:5e:72:cc	down	1500	ethernet
ens0c3	08:0c:27:9c:45:a9	up	1500	ethernet
ens0c8	08:0c:27:43:34:ff	up	1500	ethernet
veth164a13a	fa:c0:b1:4f:2:43	up	1500	ethernet
vethbc34aa0	26:87:5c:a9:8b:ab	up	1500	ethernet

Rows per page: 10

Network ports (19) 🔄 Refresh 📄 Export formatted

🔍

Local port	Local IP address	Process	PID	State	Protocol
22	0.0.0.0	sshd	392	listening	tcp
22	::	sshd	392	listening	tcp6
53	127.0.0.54	systemd-resolve	303	listening	tcp
53	127.0.0.53	systemd-resolve	303	listening	tcp
53	127.0.0.54	systemd-resolve	303		udp
53	127.0.0.53	systemd-resolve	303		udp
5355	::	systemd-resolve	303	listening	tcp6
5355	::	systemd-resolve	303		udp6
5355	0.0.0.0	systemd-resolve	303	listening	tcp
5355	0.0.0.0	systemd-resolve	303		udp

Rows per page: 10

Network settings (12) 🔄 Refresh 📄 Export formatted

🔍

Interface ↑	Address	Netmask	Protocol	Broadcast
br-4242931631b4	fe80::42:3eff:fe73:60ff	ffff:ffff:ffff:ffff::	IPv6	
br-4242931631b4	172.19.0.1	255.255.0.0	IPv4	172.19.255.255
br-8674330ab1a	172.20.0.1	255.255.0.0	IPv4	172.20.255.255
br-aa44d528d08	fe80::42:2aff:fe26:5ccc	ffff:ffff:ffff:ffff::	IPv6	
br-aa44d528d08	172.18.0.1	255.255.0.0	IPv4	172.18.255.255
docker0	172.17.0.1	255.255.0.0	IPv4	172.17.255.255
ens0c3	172.1.0.20	255.255.255.0	IPv4	172.1.0.255
ens0c3	fe80::a00:27ff:fc0c:45a9	ffff:ffff:ffff:ffff::	IPv6	
ens0c8	fe80::a00:27ff:fe43:34ff	ffff:ffff:ffff:ffff::	IPv6	

wiki 📄 Generate report

Cores: 2 Memory: 960.54 MB Arch: x86_64 Operating system: Debian GNU/Linux 12 (bookworm) CPU: Intel(R) Xeon(R) Platinum 8272CL CPU @ 2.60GHz Host name: wiki Board serial: 0 Last scan: Oct 6, 2025 @ 14:21:24.000

Network interfaces (8) 🔄 Refresh 📄 Export formatted

🔍

Name ↑	MAC	State	MTU	Type
br-4b5f1c2f9f23	02:42:ce:13:ba:13	up	1500	ethernet
br-4ae006ae4309e	02:42:49:ba:15:1d	up	1500	ethernet
docker0	02:42:4b:b1:31:63	down	1500	ethernet
ens0c3	08:0c:27:36:10:ee	up	1500	ethernet
ens0c8	08:0c:27:76:cc:f5	up	1500	ethernet
veth08af583	8a:52:12:dff:8b:b4	up	1500	ethernet
vethAdd1e60	72:70:29:bc:0f:6d	up	1500	ethernet
vethc207045	6a:ec:3f:ef:bac:5	up	1500	ethernet

Rows per page: 10

Network ports (15) 🔄 Refresh 📄 Export formatted

🔍

Local port	Local IP address	Process	PID	State	Protocol
22	::	sshd	385	listening	tcp6
22	0.0.0.0	sshd	385	listening	tcp
53	127.0.0.53	systemd-resolve	351		udp
53	127.0.0.54	systemd-resolve	351		udp
53	127.0.0.54	systemd-resolve	351	listening	tcp
53	127.0.0.53	systemd-resolve	351	listening	tcp
443	0.0.0.0	nginx	1221	listening	tcp
443	::	nginx	1221	listening	tcp6
3000	::	docker-proxy	710	listening	tcp6
3000	0.0.0.0	docker-proxy	704	listening	tcp

Rows per page: 10

Network settings (12) 🔄 Refresh 📄 Export formatted

🔍

Interface ↑	Address	Netmask	Protocol	Broadcast
br-4b5f1c2f9f23	fe80::42:ceff:fe13:ba13	ffff:ffff:ffff:ffff::	IPv6	
br-4b5f1c2f9f23	172.20.0.1	255.255.0.0	IPv4	172.20.255.255
br-4ae006ae4309e	fe80::42:49ff:feba:151d	ffff:ffff:ffff:ffff::	IPv6	
br-4ae006ae4309e	172.18.0.1	255.255.0.0	IPv4	172.18.255.255
docker0	172.17.0.1	255.255.0.0	IPv4	172.17.255.255
ens0c3	fe80::a00:27ff:fe36:10ee	ffff:ffff:ffff:ffff::	IPv6	
ens0c3	172.1.0.10	255.255.255.0	IPv4	172.1.0.255
ens0c8	172.0.99.10	255.255.255.0	IPv4	172.0.99.255
ens0c8	fe80::a00:27ff:fe76:ccf5	ffff:ffff:ffff:ffff::	IPv6	

4.3. Enhancing network security with threat intelligence

Briefly explain what threat intelligence is and how it can help enhance network security. Bring MITRE ATT&CK as an example and explore how the MITRE ATT&CK framework contributes as a structured source of threat intelligence by cataloguing adversary tactics, techniques, and procedures (TTPs) and how this information can help in detecting, classifying, and mitigating attacks within SIEM environment.

What is Threat Intelligence?

Threat intelligence refers to the collection, analysis, and dissemination of information about potential or active cyber threats. It helps organisations understand attacker behaviour, techniques, and emerging vulnerabilities. By integrating threat intelligence into security systems, organisations can detect threats faster, prioritize security responses, and proactively mitigate risks before they impact critical systems.

Role of MITRE ATT&CK Framework:

The MITRE ATT&CK framework is a structured knowledge base of real-world adversary tactics, techniques, and procedures (TTPs). It maps attacks in a standardized format, helping security teams identify attack patterns, associate them with known threat groups, and anticipate potential threats.

Integration with SIEM (Wazuh example):

By integrating MITRE ATT&CK into a SIEM solution like Wazuh, collected logs and events from agents can be correlated with known attack techniques. This allows:

Detection: SIEM alerts can be linked to specific MITRE techniques, helping identify adversary activity in real-time.

Classification: Detected events can be categorized according to the associated tactics and techniques, improving understanding of the attack chain.

Mitigation: Security teams can implement controls and response strategies aligned with the techniques used by attackers, reducing risk and enhancing incident response.

4.4. Identifying network attack techniques with MITRE ATT&CK

Name and describe two commonly known network-based attack techniques. For each method, identify and explain in 2 to 3 sentences the adversary groups that have used it and 2 – 3 sentences to describe the mitigation strategies to defend against it and the software tools commonly used in these attacks. Keep the description concise and write in your own words.

Network Service Discovery (T1046) is when attackers scan a network to find hosts and the services they run, like web servers or SSH. They do this to map the environment and find weak points they can attack. Groups such as menuPass, Tropic Trooper, Threat Group-3390, and TeamTNT have used discovery techniques to locate targets before moving on to exploitation. To stop or slow discovery, use network segmentation so attackers can't see everything, and block or limit unnecessary services so there's less to find. An IDS/IPS or firewall can spot and block

scanning patterns, and logging those events into a SIEM helps correlate scans across hosts. Common tools attackers use are Nmap and Masscan, which can quickly list open ports and services.

Password Spraying (T1110.003) is when attackers try a small set of common passwords across many user accounts instead of brute forcing one account. This method avoids lockouts and blends in with normal login traffic, so it can fly under the radar. Groups like APT29 and FIN7 have used password spraying as a way to get initial access or steal credentials. The best defence is multi-factor authentication (MFA) so passwords alone don't grant access, and enforcing strong password rules reduces the chance a guess will work. Rate limits, account lockout policies, and CAPTCHAs make automated spraying harder, while a SIEM (like Wazuh) that watches for many failed logins across accounts will help spot an attack. Attackers commonly automate spraying with tools like Hydra or CrackMapExec.

Provide **screenshots** of MITRE ATT&CK showing the details of the two selected techniques. Ensure that the screenshots display information such as the associated groups, software, mitigation strategies, techniques, and tactics. You may need to take multiple screenshots for each attack technique.

ID	Name	Created Time	Modified Time	Version
T1046	Network Service Discovery	May 31, 2017 @ 21:30:43.915	Mar 30, 2023 @ 21:01:43.682	3.0
Description				
Adversaries may attempt to get a listing of services running on remote hosts and local network infrastructure devices, including those that may be vulnerable to remote software exploitation. Common methods to acquire this information include port and/or vulnerability scans using tools that are brought onto a system.(Citation: CISA AR21-126A FIVEHANDS May 2021)				
Within cloud environments, adversaries may attempt to discover services running on other cloud hosts. Additionally, if the cloud environment is connected to a on-premises environment, adversaries may be able to identify services running on non-cloud systems as well.				
Within macOS environments, adversaries may use the native Bonjour application to discover services running on other macOS hosts within a network. The Bonjour mDNSResponder daemon automatically registers and advertises a host's registered services on the network. For example, adversaries can use a mDNS query (such as <code>dns-sd -B _ssh._tcp .</code>) to find other systems broadcasting the ssh service.(Citation: apple doco Bonjour description)(Citation: macOS APT Activity Bradley)				

Groups

ID	Name	Description ↑
G0050	APT32	APT32 is a suspected Vietnam-based threat group that has been active since at least 2014. The group has targeted multiple private sector industries as well as foreign governments, dissidents, and journalists with a strong focus on Southeast Asian countries like Vietnam, the Philippines, Laos, and Cambodia. They have extensively used strategic web compromises to compromise victims.(Citation: FireEye APT32 May 2017)(Citation: Volatility OceanLotus Nov 2017)(Citation: ESET OceanLotus)
G0087	APT39	APT39 is one of several names for cyber espionage activity conducted by the Iranian Ministry of Intelligence and Security (MOIS) through the front company Rana Intelligence Computing since at least 2014. APT39 has primarily targeted the travel, hospitality, academic, and telecommunications industries in Iran and across Asia, Africa, Europe, and North America to track individuals and entities considered to be a threat by the MOIS.(Citation: FireEye APT39 Jan 2019)(Citation: Symantec Chafer Dec 2015)(Citation: FBI FLASH APT39 September 2020)(Citation: Dept. of Treasury Iran Sanctions September 2020)(Citation: DOJ Iran Indictments September 2020)
G0096	APT41	APT41 is a threat group that researchers have assessed as Chinese state-sponsored espionage group that also conducts financially-motivated operations. Active since at least 2012, APT41 has been observed targeting healthcare, telecom, technology, and video game industries in 14 countries. APT41 overlaps at least partially with public reporting on groups including BARIUM and Winnti Group.(Citation: FireEye APT41 Aug 2019)(Citation: Group IB APT 41 June 2021)
G0135	BackdoorDiplomacy	BackdoorDiplomacy is a cyber espionage threat group that has been active since at least 2017. BackdoorDiplomacy has targeted Ministries of Foreign Affairs and telecommunication companies in Africa, Europe, the Middle East, and Asia.(Citation: ESET BackdoorDiplomacy Jun 2021)
G0098	BlackTech	BlackTech is a suspected Chinese cyber espionage group that has primarily targeted organizations in East Asia-particularly Taiwan, Japan, and Hong Kong-and the US since at least 2013. BlackTech has used a combination of custom malware, dual-use tools, and living off the land tactics to compromise media, construction, engineering, electronics, and financial company networks.(Citation: TrendMicro BlackTech June 2017)(Citation: Symantec Palmerworm Sep 2020)(Citation: Reuters Taiwan BlackTech August 2020)

Rows per page: 5

Mitigations

ID	Name ↓	Description
M1030	Network Segmentation	Architect sections of the network to isolate critical systems, functions, or resources. Use physical and logical segmentation to prevent access to potentially sensitive systems and information. Use a DMZ to contain any internet-facing services that should not be exposed from the internal network. Configure separate virtual private cloud (VPC) instances to isolate critical cloud systems.
M1031	Network Intrusion Prevention	Use intrusion detection signatures to block traffic at network boundaries.
M1042	Disable or Remove Feature or Program	Remove or deny access to unnecessary and potentially vulnerable software to prevent abuse by adversaries.

Rows per page: 5

Software

ID	Name ↓	Description
S0412	ZxShell	ZxShell is a remote administration tool and backdoor that can be downloaded from the Internet, particularly from Chinese hacker websites. It has been used since at least 2004.(Citation: FireEye APT41 Aug 2019)(Citation: Talos ZxShell Oct 2014)
S0341	Xbash	Xbash is a malware family that has targeted Linux and Microsoft Windows servers. The malware has been tied to the Iron Group, a threat actor group known for previous ransomware attacks. Xbash was developed in Python and then converted into a self-contained Linux ELF executable by using PyInstaller.(Citation: Unit42 Xbash Sept 2018)
S0117	XTunnel	XTunnel a VPN-like network proxy tool that can relay traffic between a C2 server and a victim. It was first seen in May 2013 and reportedly used by APT28 during the compromise of the Democratic National Committee. (Citation: CrowdStrike DNC June 2016) (Citation: Invincea XTunnel) (Citation: ESET Sednit Part 2)
S0374	SpeakUp	SpeakUp is a Trojan backdoor that targets both Linux and OSX devices. It was first observed in January 2019. (Citation: CheckPoint SpeakUp Feb 2019)
S0692	SILENTRINITY	SILENTRINITY is an open source remote administration and post-exploitation framework primarily written in Python that includes stagers written in Powershell, C, and Boo. SILENTRINITY was used in a 2019 campaign against Croatian government agencies by unidentified cyber actors. (Citation: GitHub SILENTRINITY March 2022)(Citation: Security Affairs SILENTRINITY July 2019)

Rows per page: 5

Tactics

ID	Name ↓	Description
TA0007	Discovery	The adversary is trying to figure out your environment. Discovery consists of techniques an adversary may use to gain knowledge about the system and internal network. These techniques help adversaries observe the environment and orient themselves before deciding how to act. They also allow adversaries to explore what they can control and what's around their entry point in order to discover how it could benefit their current objective. Native operating system tools are often used toward this post-compromise information-gathering objective.

Rows per page: 5

Details

ID

T1110.003

Name

Password Spraying

Created Time

Feb 11, 2020 @ 18:39:25.122

Modified Time

Apr 14, 2023 @ 23:04:38.816

Version

1.3

Description

Adversaries may use a single or small list of commonly used passwords against many different accounts to attempt to acquire valid account credentials. Password spraying uses one password (e.g. 'Password01'), or a small list of commonly used passwords, that may match the complexity policy of the domain. Logins are attempted with that password against many different accounts on a network to avoid account lockouts that would normally occur when brute forcing a single account with many passwords. (Citation: BlackHillsInfosec Password Spraying)

Typically, management services over commonly used ports are used when password spraying. Commonly targeted services include the following:

- SSH (22/TCP)
- Telnet (23/TCP)
- FTP (21/TCP)
- NetBIOS / SMB / Samba (139/TCP & 445/TCP)
- LDAP (389/TCP)
- Kerberos (88/TCP)
- RDP / Terminal Services (3389/TCP)
- HTTP/HTTP Management Services (80/TCP & 443/TCP)
- MSSQL (1433/TCP)
- Oracle (1521/TCP)
- MySQL (3306/TCP)
- VNC (5900/TCP)

In addition to management services, adversaries may "target single sign-on (SSO) and cloud-based applications utilizing federated authentication protocols," as well as externally facing email applications, such as Office 365. (Citation: US-CERT TA18-068A 2018)

In default environments, LDAP and Kerberos connection attempts are less likely to trigger events over SMB, which creates Windows "logon failure" event ID 4625.

Groups

ID	Name	Description
G0122	Silent Librarian	Silent Librarian is a group that has targeted research and proprietary data at universities, government agencies, and private sector companies worldwide since at least 2013. Members of Silent Librarian are known to have been affiliated with the Iran-based Mabna Institute which has conducted cyber intrusions at the behest of the government of Iran, specifically the Islamic Revolutionary Guard Corps (IRGC).(Citation: DOJ Iran Indictments March 2018)(Citation: Phish Labs Silent Librarian)(Citation: Malwarebytes Silent Librarian October 2020)
G0077	Leafminer	Leafminer is an Iranian threat group that has targeted government organizations and business entities in the Middle East since at least early 2017. (Citation: Symantec Leafminer July 2018)
G0032	Lazarus Group	Lazarus Group is a North Korean state-sponsored cyber threat group that has been attributed to the Reconnaissance General Bureau.(Citation: US-CERT HIDDEN COBRA June 2017)(Citation: Treasury North Korean Cyber Groups September 2019) The group has been active since at least 2009 and was reportedly responsible for the November 2014 destructive wiper attack against Sony Pictures Entertainment as part of a campaign named Operation Blockbuster by Novetta. Malware used by Lazarus Group correlates to other reported campaigns, including Operation Flame, Operation 1Mission, Operation Troy, DarkSeoul, and Ten Days of Rain. (Citation: Novetta Blockbuster) North Korean group definitions are known to have significant overlap, and some security researchers report all North Korean state-sponsored cyber activity under the name Lazarus Group instead of tracking clusters or subgroups, such as Andariel , APT37 , APT38 , and Kimsuky .

G1001	HEXANE	HEXANE is a cyber espionage threat group that has targeted oil & gas, telecommunications, aviation, and internet service provider organizations since at least 2017. Targeted companies have been located in the Middle East and Africa, including Israel, Saudi Arabia, Kuwait, Morocco, and Tunisia. HEXANE 's TTPs appear similar to APT33 and OilRig but due to differences in victims and tools it is tracked as a separate entity.(Citation: Dragos Hexane)(Citation: Kaspersky Lyceum October 2021)(Citation: ClearSky Siamesekitten August 2021)(Citation: Accenture Lyceum Targets November 2021)
G0114	Chimera	Chimera is a suspected China-based threat group that has been active since at least 2018 targeting the semiconductor industry in Taiwan as well as data from the airline industry.(Citation: Cyrcraft Chimera April 2020)(Citation: NCC Group Chimera January 2021)
Rows per page: 5		

Mitigations

ID	Name	Description
M1027	Password Policies	Set and enforce secure password policies for accounts.
M1032	Multi-factor Authentication	Use two or more pieces of evidence to authenticate to a system; such as username and password in addition to a token from a physical smart card or token generator.
M1036	Account Use Policies	Configure features related to account use like login attempt lockouts, specific login times, etc.
Rows per page: 5		

Software

ID	Name	Description
S0413	MailSniper	MailSniper is a penetration testing tool for searching through email in a Microsoft Exchange environment for specific terms (passwords, insider intel, network architecture information, etc.). It can be used by a non-administrative user to search their own email, or by an Exchange administrator to search the mailboxes of every user in a domain.(Citation: GitHub MailSniper)
S0362	Linux Rabbit	Linux Rabbit is malware that targeted Linux servers and IoT devices in a campaign lasting from August to October 2018. It shares code with another strain of malware known as Rabbot. The goal of the campaign was to install cryptocurrency miners onto the targeted servers and devices.(Citation: Anomall Linux Rabbit 2018)
S0488	CrackMapExec	CrackMapExec , or CME, is a post-exploitation tool developed in Python and designed for penetration testing against networks. CrackMapExec collects Active Directory information to conduct lateral movement through targeted networks.(Citation: CME Github September 2018)
S0606	Bad Rabbit	Bad Rabbit is a self-propagating ransomware that affected the Ukrainian transportation sector in 2017. Bad Rabbit has also targeted organizations and consumers in Russia. (Citation: Secure List Bad Rabbit)(Citation: ESET Bad Rabbit)(Citation: Dragos IT ICS Ransomware)
Rows per page: 5		

Tactics

ID	Name	Description
TA0006	Credential Access	The adversary is trying to steal account names and passwords. Credential Access consists of techniques for stealing credentials like account names and passwords. Techniques used to get credentials include keylogging or credential dumping. Using legitimate credentials can give adversaries access to systems, make them harder to detect, and provide the opportunity to create more accounts to help achieve their goals.

4.5. Complementary Control to SIEM and Threat Intel

Name and explain a complementary control that could be used alongside SIEM and threat intelligence.

A Next-Generation Firewall (NGFW) is a strong complementary control because it does more than just filter ports — it inspects traffic at the application layer, enforces granular policies (who can use which apps, when and how), and includes built-in intrusion prevention so many attacks are blocked before they produce logs for the SIEM. By placing enforcement at the network edge and at key internal network boundaries, an NGFW reduces the volume of noisy, low-value events that would otherwise overwhelm Wazuh, letting the SIEM focus on higher-confidence detections and coordinated threats. Its application awareness and user-identity integration help prevent lateral movement and enforce least-privilege access, while TLS/SSL inspection (where feasible) uncovers malicious payloads hidden in encrypted traffic — a major advantage when attackers use HTTPS for C2 or data exfiltration. NGFWs also consume threat-intelligence feeds and reputation lists to block known malicious IPs/domains in real time, and they produce rich, contextual logs (app, user, URL, threat) that improve correlation and incident triage in the SIEM. Finally, NGFWs support network segmentation, QoS and centralized policy management, which together harden the environment and speed response; the trade-offs are added operational overhead (managing rules, tuning for false positives, and careful handling of SSL inspection), but when integrated with Wazuh and ATT&CK-based threat intelligence the prevention + detection combination substantially raises the bar for attackers.